

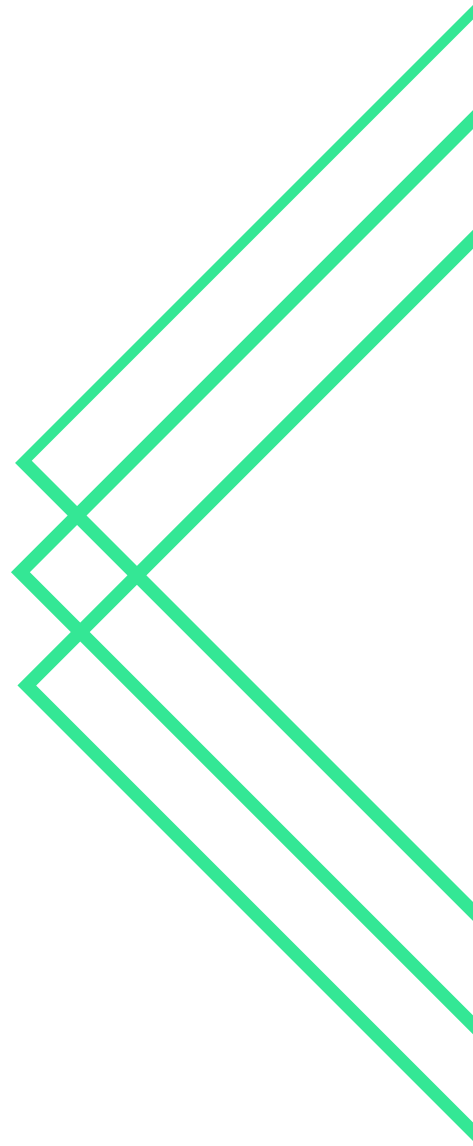
ACTIVIDAD 04

UNA PÁGINA DEMASIADO CONVINCENTE

Luis Emmanuel Aronia Silva
182979
Universidad Politecnica de San Luis Potosi
Semestre: Noveno
Octubre 2026

Indice

- Objetivo de la actividad
- Descripción del escenario
- Configuración del laboratorio
- Evidencias y descripción del funcionamiento
- Explicación del flujo de captura de información
- Controles de seguridad
Propuestos
- Conclusión
- Referencias



Objetivos

Objetivo General: Implementar y analizar, dentro de un entorno de laboratorio aislado y seguro, una simulación de ataque de ingeniería social utilizando la herramienta Social-Engineer Toolkit (SET). A través de la creación de un portal web ficticio, se busca comprender técnicamente el funcionamiento de los métodos de captura de credenciales y reconocer las vulnerabilidades relacionadas al factor humano.

Objetivos Específicos:

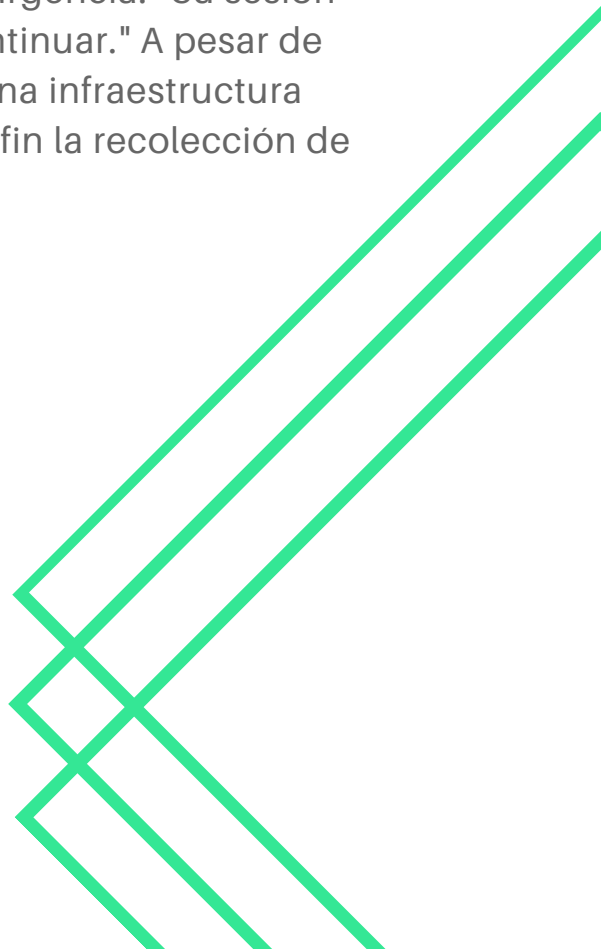
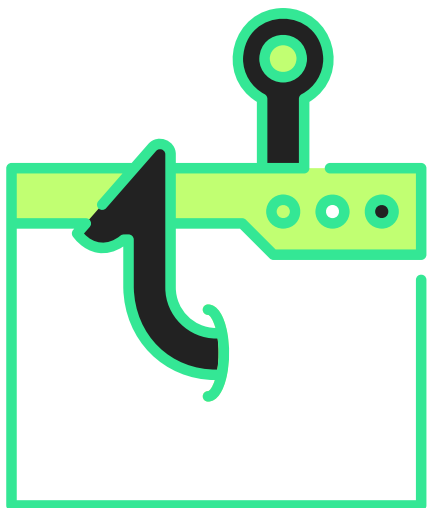
- Configurar un entorno de ataque local utilizando el módulo Credential Harvester de SET.
- Diseñar e implementar una página web en HTML que simule de manera convincente un portal de autenticación institucional.
- Analizar el tráfico y el flujo de información durante la transmisión de datos
- Demostrar la persistencia de los datos capturados por la herramienta ofensiva.

Descripción del escenario

El área de seguridad de la información de la organización ha detectado una campaña activa de phishing dirigida a los alumnos de una institución.

Varios empleados han reportado la recepción de comunicaciones alarmantes que exigen la actualización inmediata de sus credenciales.

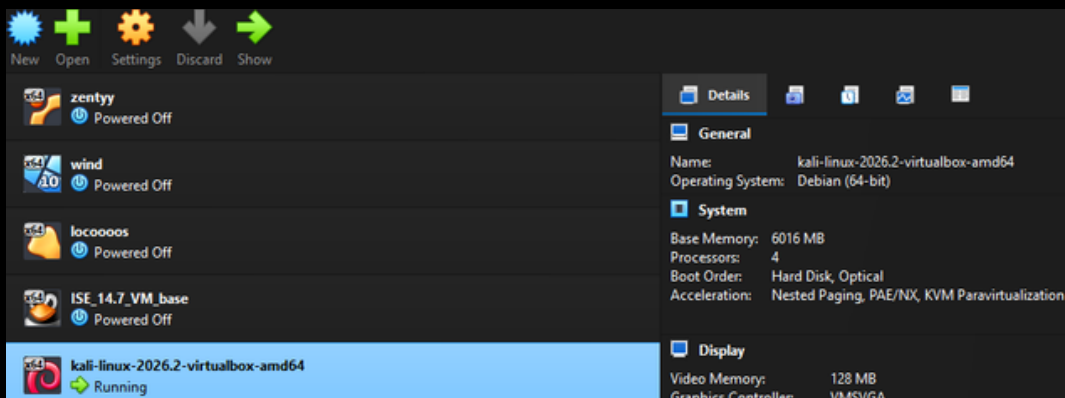
Estas comunicaciones incluyen un hipervínculo que redirige a un portal web diseñado para suplantar la identidad visual de la intranet de la empresa. Dicho portal cuenta logotipo institucional, campos de entrada para el nombre de usuario y la contraseña, y muestra un mensaje diseñado para generar un sentido de urgencia: "Su sesión ha expirado. Inicie sesión nuevamente para continuar." A pesar de su apariencia legítima, el sitio está alojado en una infraestructura controlada por un atacante y tiene como único fin la recolección de las credenciales de acceso de las víctimas.



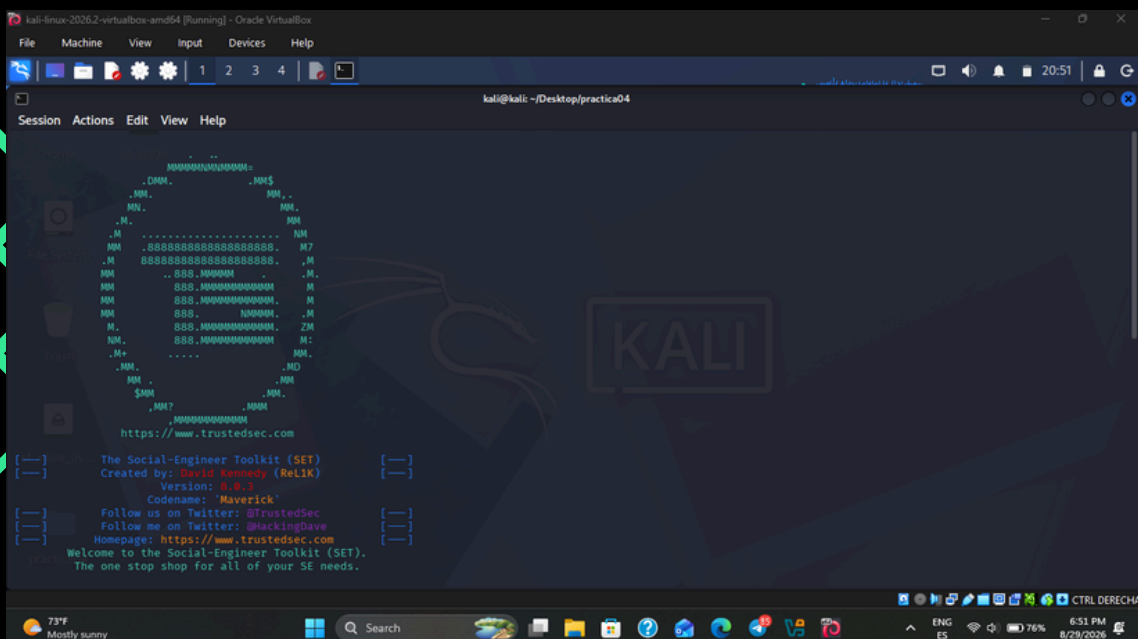
Configuración del laboratorio

El entorno de pruebas se desarrolló garantizando un aislamiento total, sin interacción con dominios externos ni servicios reales. La arquitectura del laboratorio consistió en:

Sistema Operativo del Atacante/Servidor: Kali Linux (Máquina Virtual).

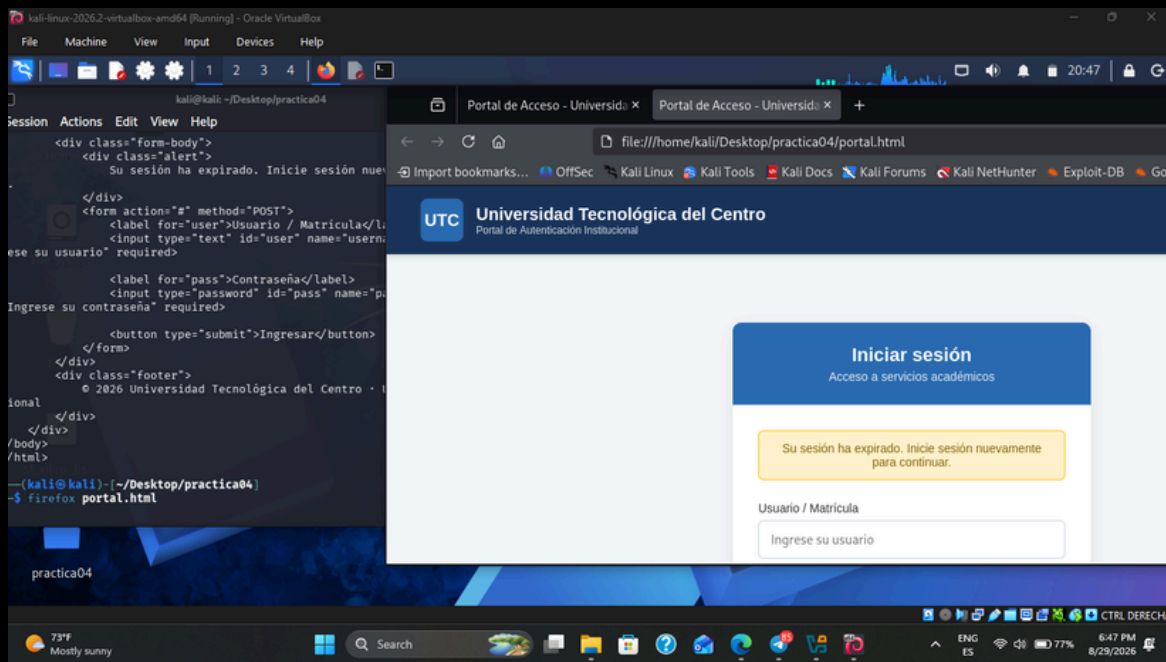


Herramienta de Explotación: Social-Engineer Toolkit (SET) versión predeterminada en Kali.



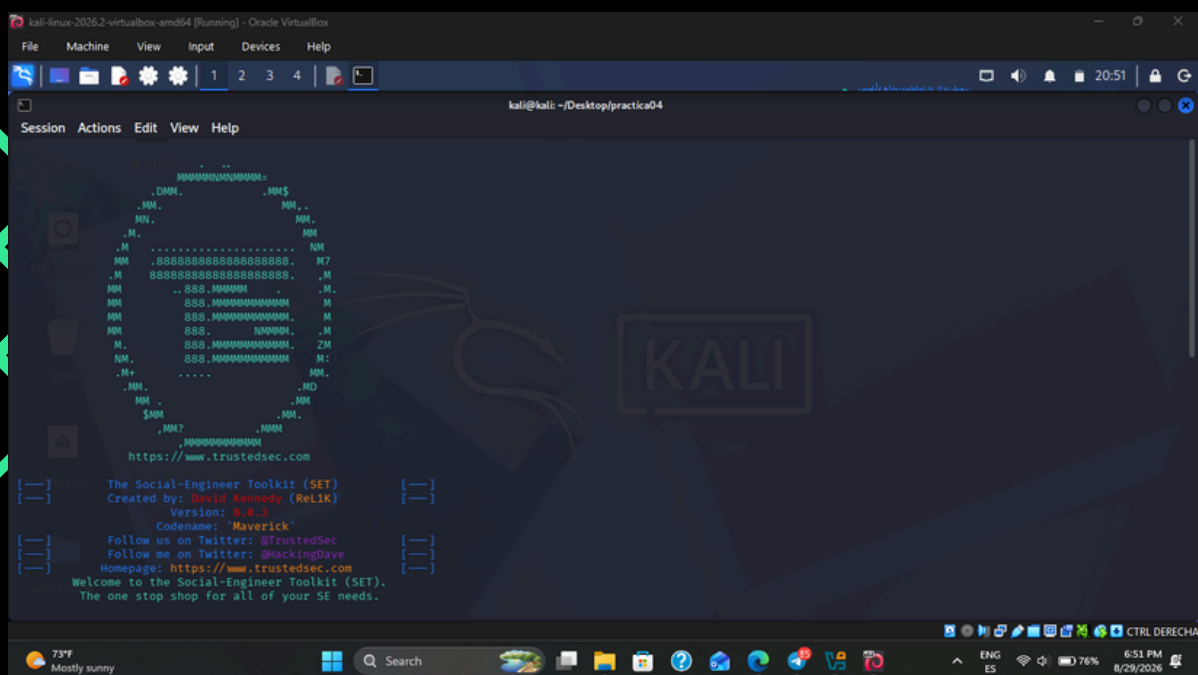
Configuración del laboratorio

Recurso Ficticio: Un archivo index.html desarrollado localmente para simular el portal institucional descrito en el escenario, configurado para enviar datos mediante post.



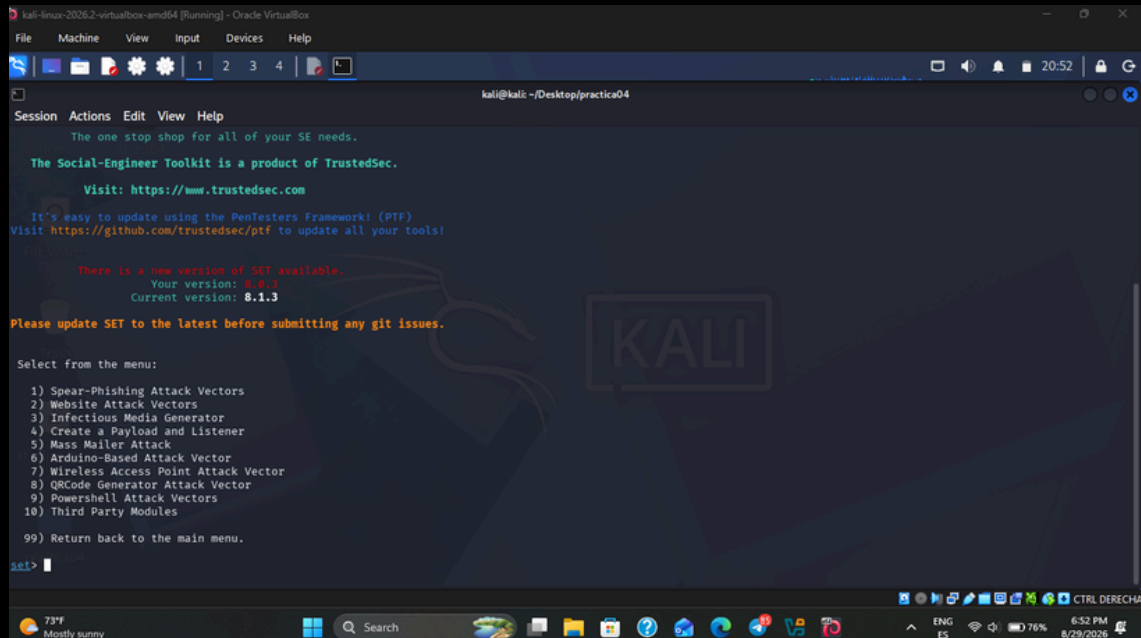
Proceso:

Se inició SET mediante la terminal (sudo setoolkit).



Configuración del laboratorio

Se seleccionó Social-Engineering Attacks > Website Attack Vectors > Credential Harvester Attack Method.



The screenshot shows the Social-Engineer Toolkit (SET) main menu. The interface is dark-themed with a 'KALI' logo in the background. The menu lists various attack vectors, including Spear-Phishing, Website Attacks, and Payload Generators. The user is currently in the 'Website Attack Vectors' section.

```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

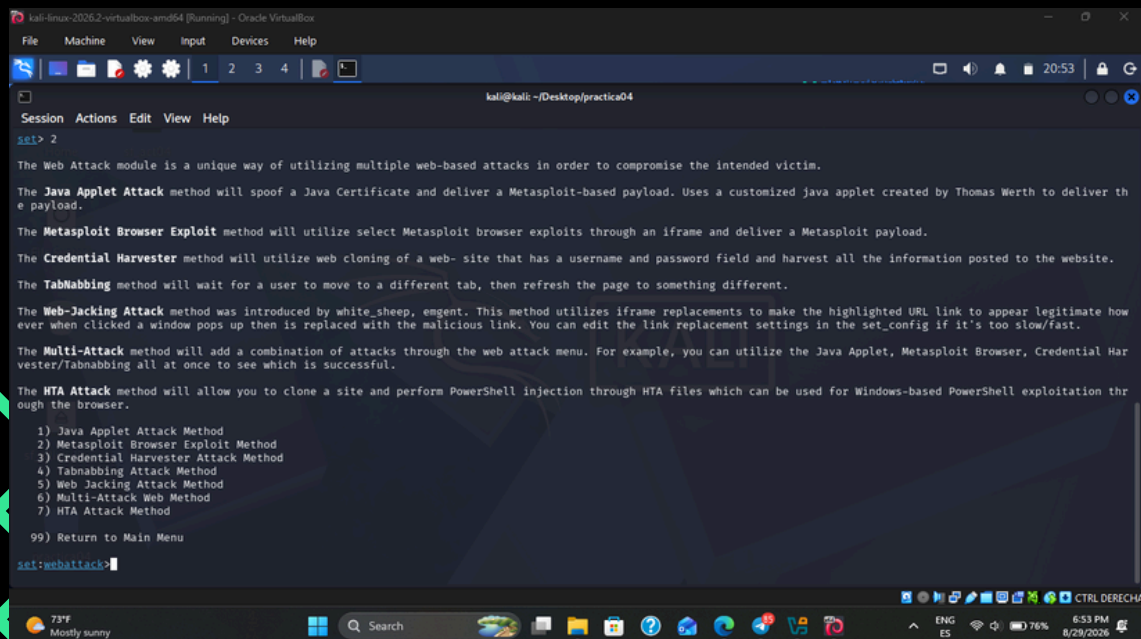
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set>
```



The screenshot shows the 'Web Attack' module options in the Social-Engineer Toolkit. The user has selected option '2' from the main menu. The screen displays detailed descriptions for various web-based attack methods, including Java Applet, Metasploit Browser Exploit, Credential Harvester, TabNabbing, Web-Jacking, Multi-Attack, and HTA attacks.

```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help
set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web-site that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web-Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

set:webattack>
```

Configuración del laboratorio

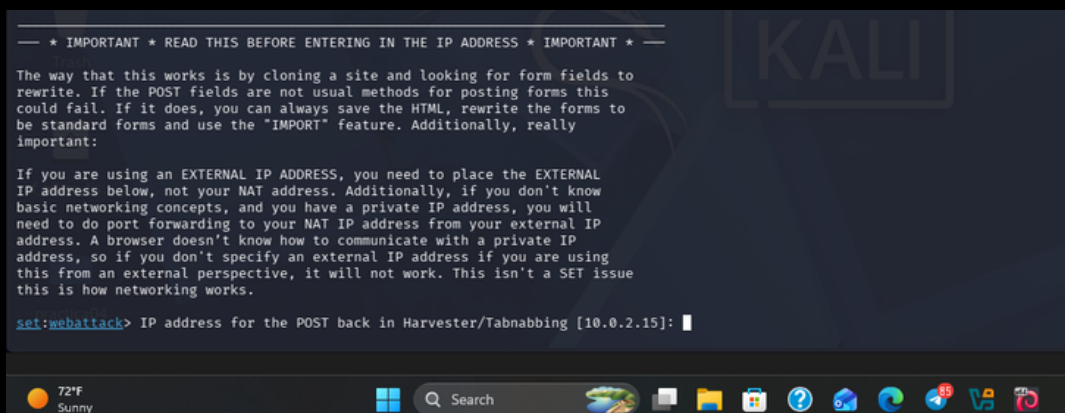
Se utilizó el método Custom Import para cargar el archivo HTML local

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

practica04
set:webattack>3
```

Se configuró apuntando a la dirección IP local de la máquina virtual



Después de dar la IP me di cuenta de un error gracias al siguiente mensaje y es que se esperaba un archivo llamado index.html y yo lo había llamado portal.html

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/practica04
[!] ERROR:index.html not found!!
[!] ERROR:Did you just put the path in, not file?
[!] Exiting the Social-Engineer Toolkit...Hack the Gibson.

Thank you for shopping with the Social-Engineer Toolkit.

Hack the Gibson... and remember... hugs are worth more than handshakes.
```


Configuración del laboratorio

Lo corriji rapidamente solo renombrando el archivo con mv

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/practica04
[!] ERROR:index.html not found!!
[!] ERROR:Did you just put the path in, not file?
[!] Exiting the Social-Engineer Toolkit...Hack the Gibson.

SE_XMux_In

Thank you for shopping with the Social-Engineer Toolkit.

Hack the Gibson...and remember...hugs are worth more than handshakes.

(kali@kali)-[~/Desktop/practica04]
└─$ mv portal.html index.html
```

Despues de renombrar el archivo volvi a repetir el proceso hasta regresar a la parte del IP, ingrese la ip de la maquina y despues me aparecieron estas dos opciones, de las cuales seleccione la numero 1 debido a que solo es un index de manera local

```
1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: 
```

Despues me pidio la URL que usaria el sitio, la asigne y el SET empezo a correr, ahora solo esta esperando que se introduzcan los datos para mostrarlos desde la misma terminal

```
Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://portalumnos.utc.edu.
mx

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:

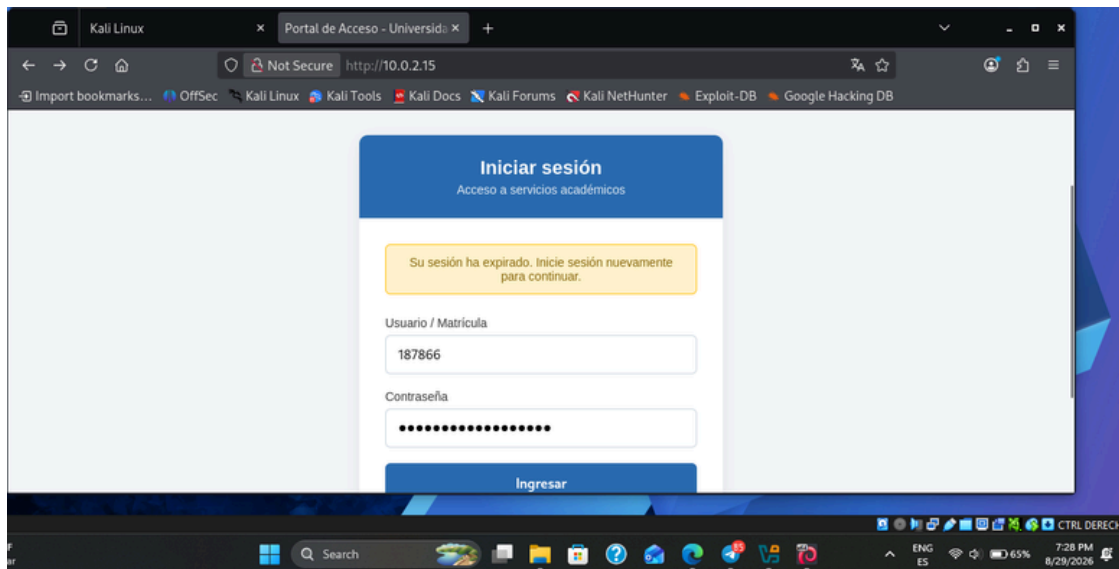
```

Evidencias y Descripción de Funcionamiento

El funcionamiento del ataque se comprobó realizando una simulación de usuario víctima desde el navegador de la máquina

Despliegue del Servicio: Al acceder a la IP configurada el servidor http levantado mediante SET funcionó correctamente mostrando el portal ficticio creado en html con el mensaje de expiración de sesión

Interacción de la Víctima: Se introdujeron credenciales ficticias de prueba en los campos correspondientes y se enviaron



Captura en Tiempo Real: En la terminal de SET, se interceptó la petición del usuario y se mostró en texto plano las credenciales de dicho usuario, sean su usuario y contraseña

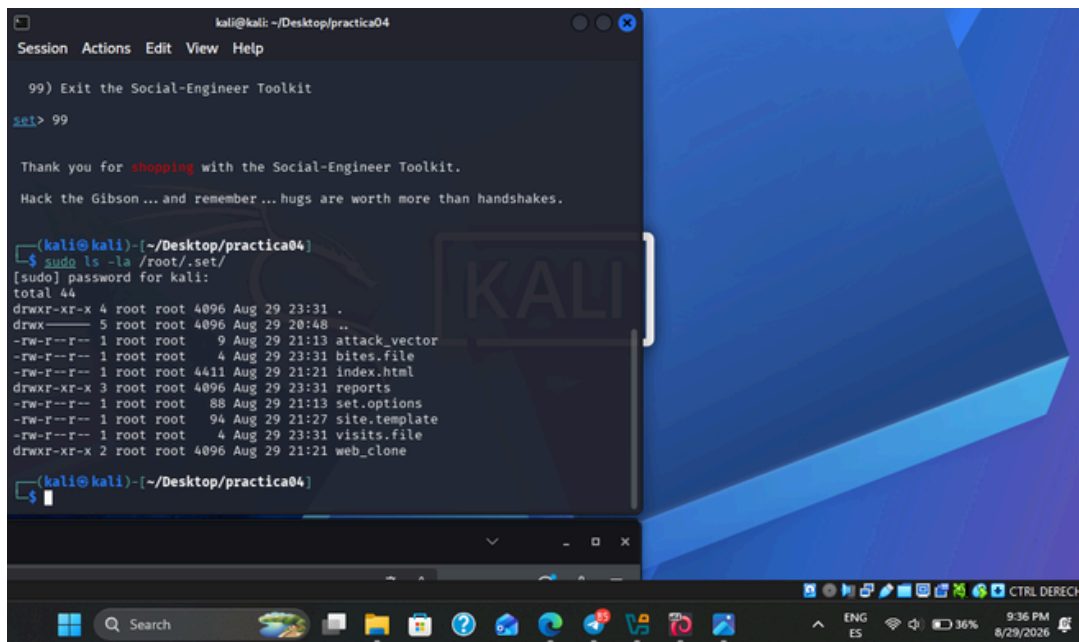
```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.1
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Desktop/practica0
[*] Index.html found. Do you want to copy the entire folder or just index.htm
1. Copy just the index.html
2. Copy the entire folder
Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://portalalumnos.utc.edu.
mx

The best way to use this attack is if username and password form fields are a
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [29/Aug/2026 21:24:14] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [29/Aug/2026 21:24:15] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=187866
POSSIBLE PASSWORD FIELD FOUND: password=PuedoVerTuContraGG
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Evidencias y Descripcion de Funcionamiento

Pesistencia de Informacion: Para comprobar el impacto real de esta herramienta se detuvo la ejecucion de SET con Control + C, y se navego entre los menus que se fueron mostrando anteriormente hasta salir de la herramienta, fue asi como navegue al directorio de almacenamiento de los reportes generados mediante el siguiente comando: **sudo ls -la /root/.set/**



```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help

99) Exit the Social-Engineer Toolkit

set> 99

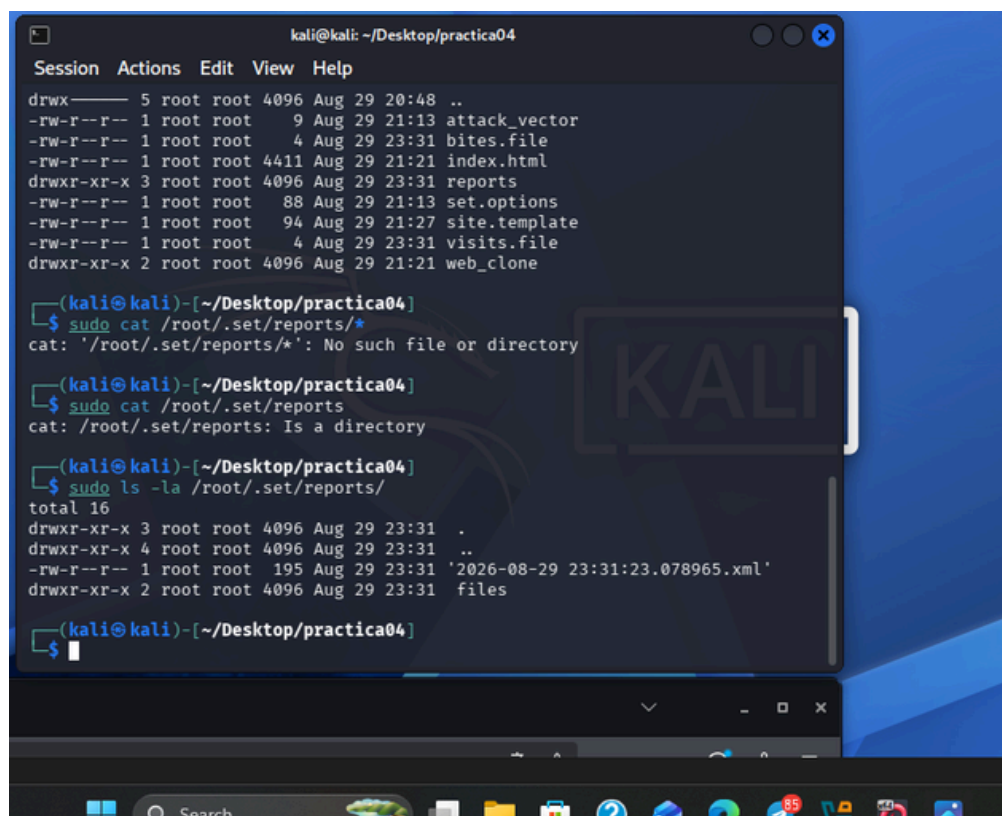
Thank you for shopping with the Social-Engineer Toolkit.

Hack the Gibson... and remember... hugs are worth more than handshakes.

(kali@kali)-[~/Desktop/practica04]
$ sudo ls -la /root/.set/
[sudo] password for kali:
total 44
drwxr-xr-x 4 root root 4096 Aug 29 23:31 .
drwx----- 5 root root 4096 Aug 29 20:48 ..
-rw-r--r-- 1 root root 9 Aug 29 21:13 attack_vector
-rw-r--r-- 1 root root 4 Aug 29 23:31 bites.file
-rw-r--r-- 1 root root 4411 Aug 29 21:21 index.html
drwxr-xr-x 3 root root 4096 Aug 29 23:31 reports
-rw-r--r-- 1 root root 88 Aug 29 21:13 set.options
-rw-r--r-- 1 root root 94 Aug 29 21:27 site.template
-rw-r--r-- 1 root root 4 Aug 29 23:31 visits.file
drwxr-xr-x 2 root root 4096 Aug 29 21:21 web_clone

(kali@kali)-[~/Desktop/practica04]
$
```

Primero se enlisto el contenido dentro de la carpeta reports y se mostro con el uso de **cat** el archivo de texto/XML generado mediante el comando , comprobando que las credenciales interceptadas quedaron guardadas permanentemente en el disco duro del atacante, listas para ser procesadas o utilizadas posteriormente.



```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help

drwx----- 5 root root 4096 Aug 29 20:48 ..
-rw-r--r-- 1 root root 9 Aug 29 21:13 attack_vector
-rw-r--r-- 1 root root 4 Aug 29 23:31 bites.file
-rw-r--r-- 1 root root 4411 Aug 29 21:21 index.html
drwxr-xr-x 3 root root 4096 Aug 29 23:31 reports
-rw-r--r-- 1 root root 88 Aug 29 21:13 set.options
-rw-r--r-- 1 root root 94 Aug 29 21:27 site.template
-rw-r--r-- 1 root root 4 Aug 29 23:31 visits.file
drwxr-xr-x 2 root root 4096 Aug 29 21:21 web_clone

(kali@kali)-[~/Desktop/practica04]
$ sudo cat /root/.set/reports/*
cat: '/root/.set/reports/*': No such file or directory

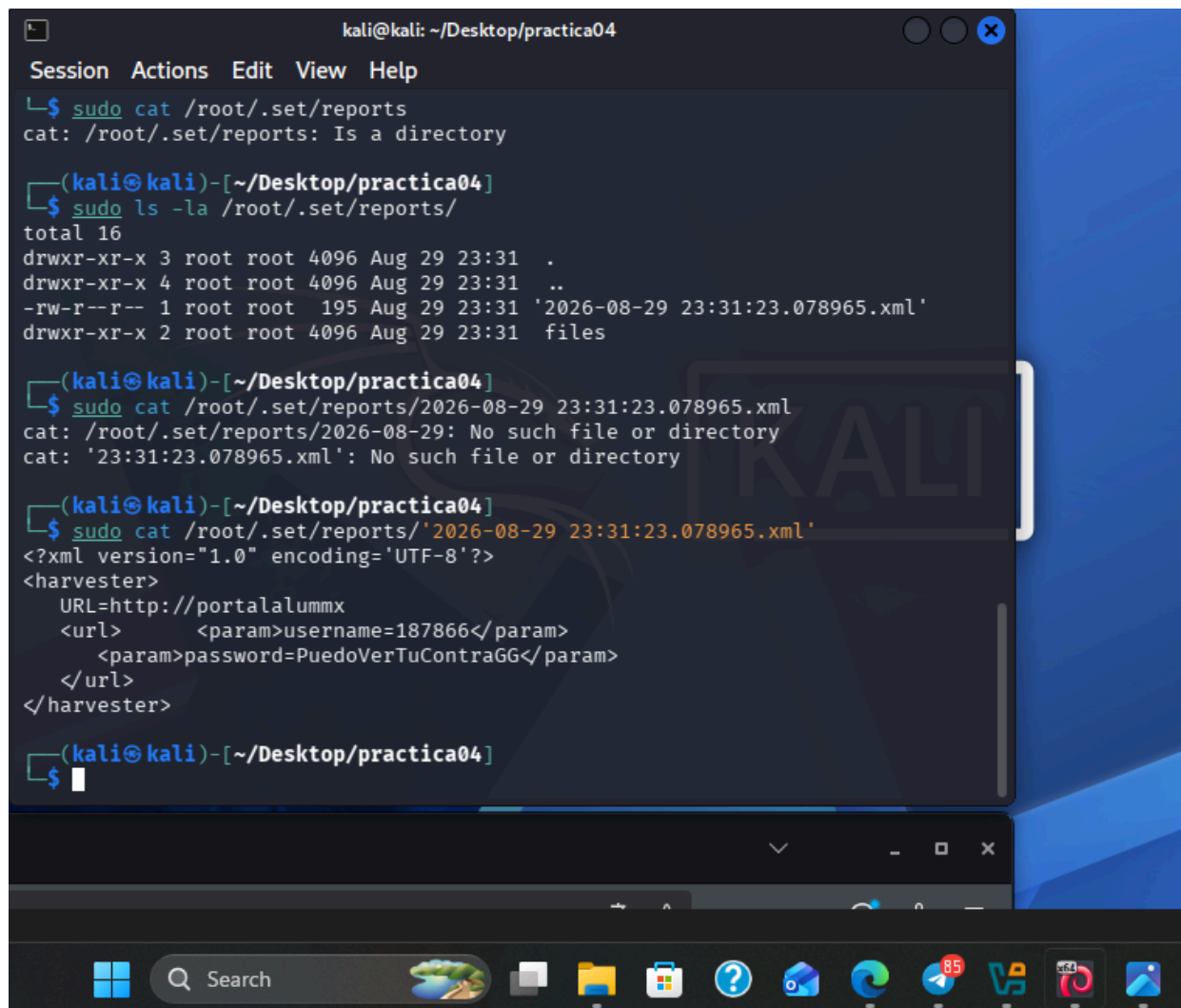
(kali@kali)-[~/Desktop/practica04]
$ sudo cat /root/.set/reports
cat: /root/.set/reports: Is a directory

(kali@kali)-[~/Desktop/practica04]
$ sudo ls -la /root/.set/reports/
total 16
drwxr-xr-x 3 root root 4096 Aug 29 23:31 .
drwxr-xr-x 4 root root 4096 Aug 29 23:31 ..
-rw-r--r-- 1 root root 195 Aug 29 23:31 '2026-08-29 23:31:23.078965.xml'
drwxr-xr-x 2 root root 4096 Aug 29 23:31 files

(kali@kali)-[~/Desktop/practica04]
$
```

Evidencias y Descripción de Funcionamiento

Como se aprecia el contenido del archivo concuerda con lo introducido en la prueba, comprobando que las credenciales interceptadas quedaron guardadas permanentemente en el disco duro del atacante, listas para ser procesadas o utilizadas posteriormente.



```
kali@kali: ~/Desktop/practica04
Session Actions Edit View Help
└─$ sudo cat /root/.set/reports
cat: /root/.set/reports: Is a directory

(kali@kali)-[~/Desktop/practica04]
└─$ sudo ls -la /root/.set/reports/
total 16
drwxr-xr-x 3 root root 4096 Aug 29 23:31 .
drwxr-xr-x 4 root root 4096 Aug 29 23:31 ..
-rw-r--r-- 1 root root 195 Aug 29 23:31 '2026-08-29 23:31:23.078965.xml'
drwxr-xr-x 2 root root 4096 Aug 29 23:31 files

(kali@kali)-[~/Desktop/practica04]
└─$ sudo cat /root/.set/reports/2026-08-29 23:31:23.078965.xml
cat: /root/.set/reports/2026-08-29: No such file or directory
cat: '23:31:23.078965.xml': No such file or directory

(kali@kali)-[~/Desktop/practica04]
└─$ sudo cat /root/.set/reports/'2026-08-29 23:31:23.078965.xml'
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  URL=http://portalalummx
  <url>      <param>username=187866</param>
            <param>password=PuedoVerTuContraGG</param>
  </url>
</harvester>

(kali@kali)-[~/Desktop/practica04]
└─$
```

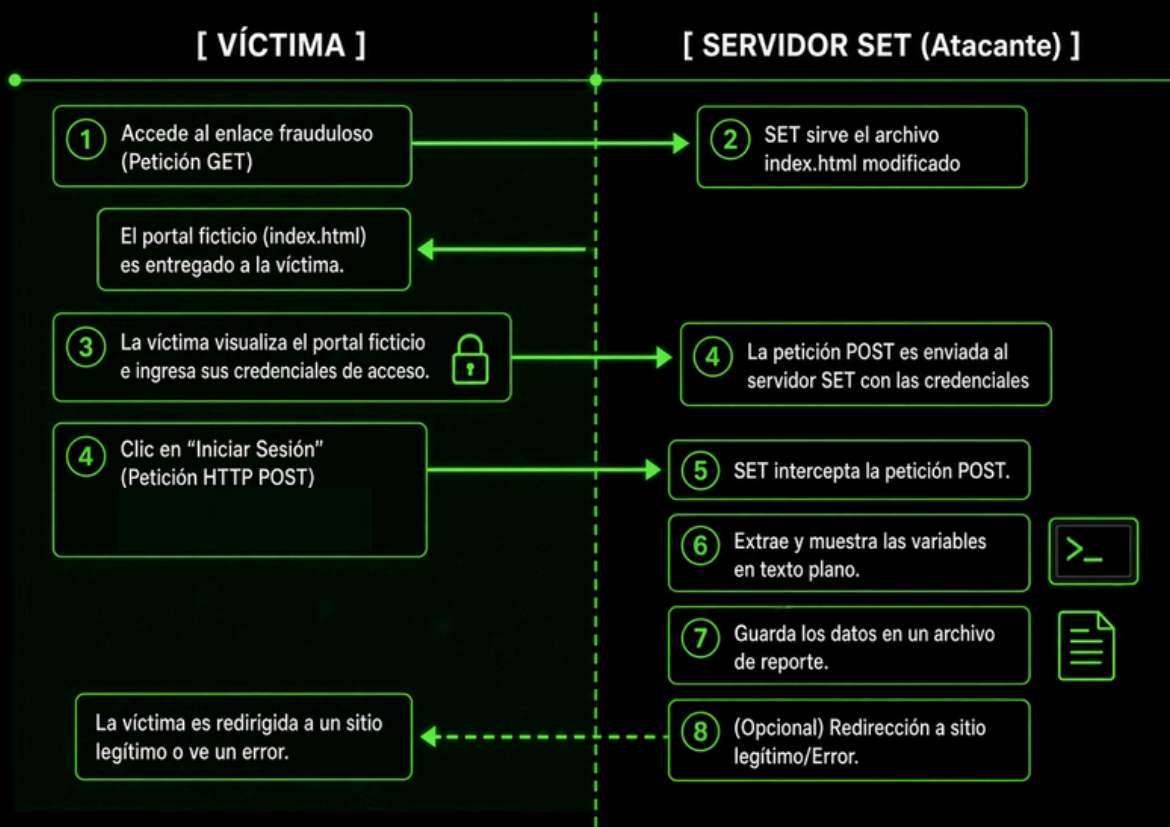
Explicación del flujo de captura de información

¿Qué es un Credential Harvester?

Es un vector de ataque informático, implementado mediante herramientas como SET, diseñado para clonar o importar portales de autenticación.

Su función principal dentro de una campaña de phishing es levantar un servidor web malicioso que intercepta la información introducida por la víctima en un formulario web antes de que (opcionalmente) la redirija al sitio web legítimo para no levantar sospechas.

Flujo de la simulación: El proceso de captura se basa en la manipulación del comportamiento estándar del protocolo HTTP. En lugar de que el formulario HTML envíe las credenciales al servidor de base de datos legítimo, la acción del formulario redirige los datos al servidor controlado por SET.



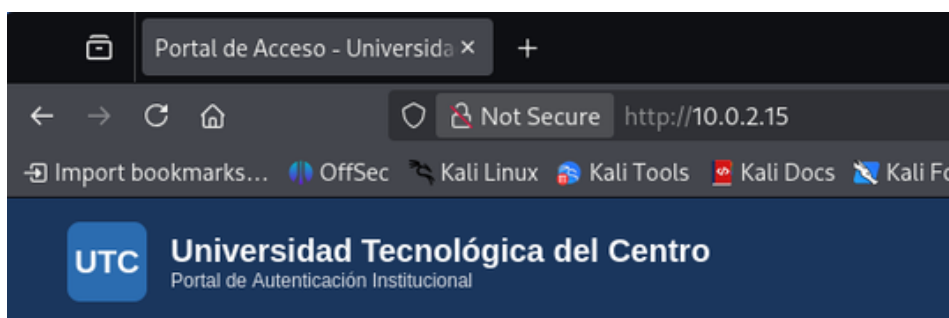
Controles de seguridad propuestos

Indicadores relevantes de phishing identificados

Dominio sospechoso o inventado: La URL mostraba `http://portalalumnos.utc.edu.mx` o directamente la IP `10.0.2.15`, no el dominio legítimo de ninguna institución real.

Uso de HTTP en lugar de HTTPS: La conexión no era cifrada. El navegador mostraba "No seguro" / "Not secure".

Ausencia de candado de seguridad: No estaba el candado que indica un certificado SSL/TLS válido.



Mensaje genérico de sesión expirada: El aviso "Su sesión ha expirado. Inicie sesión nuevamente para continuar" es una técnica clásica de urgencia para presionar al usuario.

Iniciar sesión

Acceso a servicios académicos

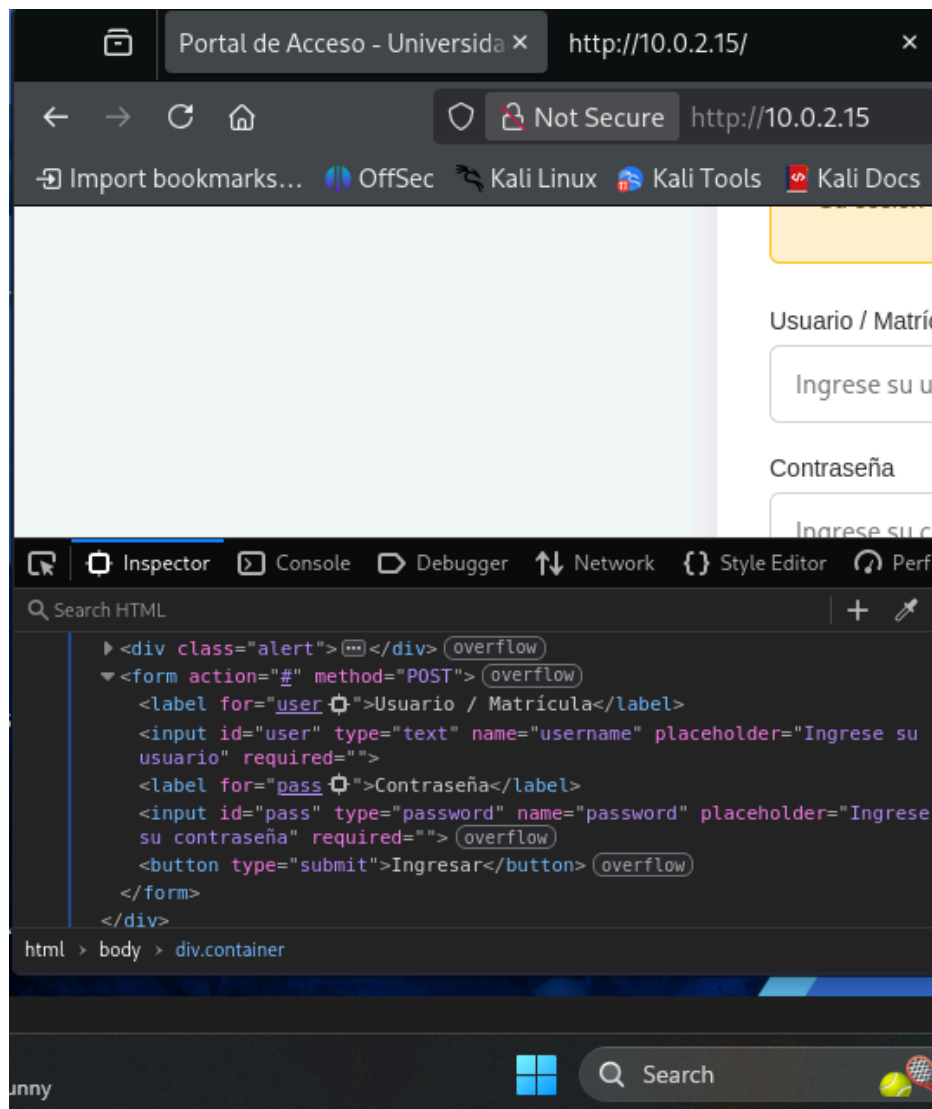
Su sesión ha expirado. Inicie sesión nuevamente para continuar.

Usuario / Matrícula

Ingresa su usuario

Controles de seguridad propuestos

Formulario que envía datos al servidor del atacante: Al inspeccionar el código o la pestaña Network se observó que el atributo `action="#"` hace que el POST se envíe a la misma URL desde la que se carga la página (la IP de SET: 10.0.2.15). Mientras que un sitio legítimo normalmente apunta a una ruta de autenticación concreta.



Controles de seguridad propuestos

Justificación, alcances y limitaciones

Control 1: Verificar siempre la URL completa

- Justificación: El dominio es uno de los indicadores más fiables. Un usuario entrenado puede detectar inmediatamente dominios inventados, IPs o pequeñas alteraciones.
- Alcance: Previene la mayoría de los ataques de phishing basados en sitios clonados o fraudulentos, siempre que el usuario revise la barra de direcciones antes de ingresar datos.
- Limitaciones: Depende completamente de la atención del usuario. No protege contra ataques de dominios que se ven casi idénticos, ni contra usuarios que no revisan la URL por prisa o costumbre.

Control 2: Inspeccionar el tráfico de red

- Justificación: Permite ver exactamente a dónde se envían las credenciales (IP o dominio de destino del POST).
- Alcance: Muy efectivo para usuarios técnicos o analistas de seguridad. Sirve tanto para detección en tiempo real como para análisis forense posterior.
- Limitaciones: Requiere conocimientos técnicos. No es viable como control masivo para usuarios finales no especializados.

Control 3: Uso de gestores de contraseñas

- Justificación: Los gestores modernos (Firefox, Bitwarden, etc.) solo autocompletan credenciales en el dominio exacto guardado. Si el dominio no coincide, no rellenan los campos.
- Alcance: Excelente control preventivo. Reduce drásticamente el éxito de sitios phishing porque el usuario nota que la contraseña no se autocompleta.
- Limitaciones: No protege si el usuario escribe manualmente las credenciales. Tampoco ayuda si el atacante logra un dominio muy similar y el usuario no se percató.

Control 4: Exigir HTTPS con certificado válido (candado)

- Justificación: Un sitio legítimo casi siempre usa HTTPS. La ausencia del candado o el aviso "No seguro" es una señal de alerta inmediata.
- Alcance: Fácil de verificar visualmente por cualquier usuario. Bloquea o advierte sobre conexiones no cifradas.
- Limitaciones: Los atacantes también pueden obtener certificados válidos. Por sí solo no garantiza que el sitio sea legítimo, solo que la conexión está cifrada.

Control 5: Revisión del código fuente del formulario

- Justificación: Permite ver el atributo action del formulario y descubrir si los datos se envían a un servidor desconocido o a una IP.
- Alcance: Muy útil en entornos de análisis o para usuarios avanzados. Confirma de forma definitiva el destino de las credenciales.
- Limitaciones: Requiere conocimientos básicos de HTML. No es un control práctico para el usuario promedio en su día a día.

Conclusion

La realización de esta práctica en un entorno controlado evidencia de manera contundente que el eslabón más vulnerable en la cadena de seguridad de la información sigue siendo el usuario. Aunque una organización invierta fuertemente en cortafuegos, sistemas de detección de intrusos y arquitecturas de red robustas (como políticas estrictas de Active Directory), un ataque de ingeniería social estructurado puede eludir estos controles técnicos simplemente manipulando la percepción de la víctima.

El uso de un Credential Harvester demuestra lo trivial que resulta para un atacante levantar una infraestructura de recolección de datos en cuestión de minutos. El sentido de urgencia y la suplantación visual son tácticas psicológicas eficaces que nublan el juicio racional. Queda de manifiesto que las defensas técnicas deben complementarse obligatoriamente con la concientización continua, la verificación de dominios y la implementación de la autenticación multifactor (MFA), la cual mitigaría drásticamente el impacto de un ataque incluso si la contraseña es interceptada



Referencias

- Hadnagy, C. (2018). Social engineering: The science of human hacking (2nd ed.). Wiley.
- Mitnick, K. D., & Simon, W. L. (2002). The art of deception: Controlling the human element of security. Wiley.
- OWASP Foundation. (2021). OWASP Top 10 - 2021: The ten most critical web application security risks.
<https://owasp.org/Top10/>
- National Institute of Standards and Technology. (2022). Digital identity guidelines (NIST Special Publication 800-63-3).
<https://doi.org/10.6028/NIST.SP.800-63-3>
- TrustedSec. (n.d.). Social-Engineer Toolkit (SET).
<https://github.com/trustedsec/social-engineer-toolkit>
- Verizon. (2024). 2024 Data Breach Investigations Report.
<https://www.verizon.com/business/resources/reports/dbir/>
- Anti-Phishing Working Group. (2024). Phishing activity trends report. <https://apwg.org/trendsreports/>
- Hadnagy, C., & Fincher, M. (2015). Phishing dark waters: The offensive and defensive sides of malicious emails. Wiley.
- Instituto Nacional de Ciberseguridad (INCIBE). (2023). Guía de phishing: Cómo identificar y prevenir ataques.
<https://www.incibe.es>
- Microsoft. (2023). Microsoft Digital Defense Report 2023.
<https://www.microsoft.com/security/business/security-strategies-guidance/microsoft-digital-defense-report>